

นโยบายความมั่นคงปลอดภัยด้านเทคโนโลยีสารสนเทศ

Information Technology Security Policy

เลขที่เอกสาร	HR-IT-002
เวอร์ชัน	3.0
วันที่มีผลบังคับใช้	1 มกราคม 2569
เจ้าของนโยบาย	ฝ่ายเทคโนโลยีสารสนเทศ ร่วมกับฝ่ายทรัพยากรบุคคล
ผู้อนุมัติ	ประธานเจ้าหน้าที่ฝ่ายเทคโนโลยีสารสนเทศ (CIO)
รอบการทบทวน	ทุก 12 เดือน หรือเมื่อพบความเสี่ยงใหม่ที่มีนัยสำคัญ

1. วัตถุประสงค์

นโยบายฉบับนี้จัดทำขึ้นเพื่อกำหนดมาตรฐานและแนวทางปฏิบัติด้านความมั่นคงปลอดภัยสารสนเทศของ บริษัท ตัวอย่างธุรกิจ จำกัด (มหาชน) เพื่อปกป้องทรัพย์สินสารสนเทศ ข้อมูลทางธุรกิจ และข้อมูลส่วนบุคคล จากความเสี่ยงด้านการเข้าถึงโดยไม่ได้รับอนุญาต การรั่วไหล การสูญหาย หรือการถูกโจมตีทางไซเบอร์ ให้สอดคล้องกับมาตรฐานสากล เช่น ISO/IEC 27001 และพระราชบัญญัติว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์

2. ขอบเขตการบังคับใช้

นโยบายนี้ใช้บังคับกับพนักงาน ผู้บริหาร ผู้รับเหมา และบุคคลภายนอกทุกรายที่เข้าถึงหรือใช้งานระบบสารสนเทศ อุปกรณ์คอมพิวเตอร์ เครือข่าย และข้อมูลของบริษัท ไม่ว่าจะเป็นปฏิบัติงานภายในหรือภายนอกสถานที่ทำงานของบริษัท

3. คำนิยาม

คำศัพท์	ความหมาย
ทรัพย์สินสารสนเทศ	ฮาร์ดแวร์ ซอฟต์แวร์ ข้อมูล และระบบเครือข่ายทั้งหมดที่บริษัทเป็นเจ้าของหรือใช้งาน
ผู้ใช้งาน	บุคคลใดก็ตามที่ได้รับอนุญาตให้เข้าถึงระบบสารสนเทศของบริษัท
เหตุการณ์ด้านความมั่นคงปลอดภัย	เหตุการณ์ที่อาจก่อให้เกิดความเสียหายต่อความลับ ความถูกต้อง หรือความพร้อมใช้งานของข้อมูล
มัลแวร์	ซอฟต์แวร์ที่ถูกออกแบบมาเพื่อสร้างความเสียหายหรือเข้าถึงระบบโดยไม่ได้รับอนุญาต

4. หลักการความมั่นคงปลอดภัยสารสนเทศ

บริษัทยึดหลักการพื้นฐาน 3 ประการในการบริหารจัดการความมั่นคงปลอดภัยสารสนเทศ:

- การรักษาความลับ (Confidentiality) — ข้อมูลเข้าถึงได้เฉพาะผู้ที่ได้รับอนุญาตเท่านั้น
- ความถูกต้องครบถ้วน (Integrity) — ข้อมูลต้องไม่ถูกแก้ไขเปลี่ยนแปลงโดยไม่ได้รับอนุญาต
- ความพร้อมใช้งาน (Availability) — ระบบและข้อมูลต้องพร้อมใช้งานเมื่อจำเป็นต้องใช้

5. การควบคุมการเข้าถึงระบบ (Access Control)

บริษัทกำหนดมาตรฐานการควบคุมการเข้าถึงระบบสารสนเทศ ดังนี้:

- ให้สิทธิการเข้าถึงตามหลักการสิทธิที่น้อยที่สุดเท่าที่จำเป็น (Principle of Least Privilege)
- รหัสผ่านต้องมีความยาวไม่น้อยกว่า 12 ตัวอักษร ประกอบด้วยตัวพิมพ์ใหญ่ ตัวพิมพ์เล็ก ตัวเลข และอักขระพิเศษ
- บังคับใช้การยืนยันตัวตนแบบหลายปัจจัย (Multi-Factor Authentication) สำหรับระบบสำคัญและการเข้าถึงจากภายนอก
- เปลี่ยนรหัสผ่านทุก 90 วัน และห้ามใช้รหัสผ่านซ้ำกับ 5 รหัสผ่านล่าสุด
- ระบบจะล็อกบัญชีผู้ใช้โดยอัตโนมัติเมื่อพบการพยายามเข้าสู่ระบบผิดพลาดเกิน 5 ครั้งติดต่อกัน
- ทบทวนสิทธิการเข้าถึงของผู้ใช้งานทุกไตรมาส และเพิกถอนสิทธิทันทีเมื่อพนักงานพ้นสภาพ

6. การใช้งานอุปกรณ์และทรัพยากรสารสนเทศอย่างเหมาะสม

- ห้ามใช้อุปกรณ์คอมพิวเตอร์ของบริษัทเพื่อกิจกรรมที่ผิดกฎหมายหรือขัดต่อจริยธรรม
- ห้ามเชื่อมต่ออุปกรณ์บันทึกข้อมูลภายนอก (USB) ที่ไม่ได้รับอนุญาตเข้ากับเครื่องคอมพิวเตอร์ของบริษัท
- การใช้อุปกรณ์ส่วนตัวเพื่อเข้าถึงข้อมูลบริษัท (BYOD) ต้องได้รับอนุมัติและติดตั้งซอฟต์แวร์บริหารจัดการอุปกรณ์
- ต้องล็อกหน้าจอคอมพิวเตอร์ทุกครั้งเมื่อไม่ได้ยืนหน้าเครื่อง

7. การป้องกันมัลแวร์และไวรัสคอมพิวเตอร์

อุปกรณ์คอมพิวเตอร์ทุกเครื่องต้องติดตั้งซอฟต์แวร์ป้องกันมัลแวร์ที่ได้รับอนุมัติจากฝ่ายเทคโนโลยีสารสนเทศ และต้องอัปเดตฐานข้อมูลไวรัสอย่างสม่ำเสมอ ห้ามปิดหรือถอนการติดตั้งซอฟต์แวร์ดังกล่าวโดยไม่ได้รับอนุญาต หากตรวจพบมัลแวร์ ผู้ใช้งานต้องตัดการเชื่อมต่อเครือข่ายทันทีและแจ้งฝ่ายเทคโนโลยีสารสนเทศโดยเร็วที่สุด

8. การเข้ารหัสข้อมูล (Encryption)

ข้อมูลที่มีความอ่อนไหวหรือเป็นความลับต้องได้รับการเข้ารหัสทั้งในขณะจัดเก็บ (Data at Rest) และขณะรับส่งผ่านเครือข่าย (Data in Transit) โดยใช้มาตรฐานการเข้ารหัสที่ได้รับการยอมรับ เช่น AES-256 และ TLS 1.2 ขึ้นไป อุปกรณ์พกพา เช่น แล็ปท็อปและฮาร์ดดิสก์ภายนอก ต้องเปิดใช้งานการเข้ารหัสฮาร์ดดิสก์เต็มรูปแบบ

9. การสำรองข้อมูลและแผนกู้คืนระบบ

ฝ่ายเทคโนโลยีสารสนเทศต้องจัดให้มีการสำรองข้อมูลระบบสำคัญเป็นประจำทุกวัน และเก็บสำเนาสำรองไว้ในสถานที่แยกจากระบบหลัก บริษัทต้องจัดทำแผนความต่อเนื่องทางธุรกิจและแผนกู้คืนระบบจากภัยพิบัติ (Disaster Recovery Plan) พร้อมทดสอบความพร้อมใช้งานอย่างน้อยปีละ 1 ครั้ง

10. การบริหารจัดการช่องโหว่และการอัปเดตซอฟต์แวร์

ระบบปฏิบัติการและซอฟต์แวร์ทั้งหมดต้องได้รับการติดตั้งแพตช์รักษาความปลอดภัยตามรอบที่ฝ่ายเทคโนโลยีสารสนเทศกำหนด โดยช่องโหว่ที่มีความเสี่ยงระดับวิกฤตต้องได้รับการแก้ไขภายใน 7 วันนับแต่วันที่ประกาศแพตช์ และต้องมีการประเมินช่องโหว่ของระบบ (Vulnerability Assessment) อย่างน้อยปีละ 2 ครั้ง

11. การใช้งานอินเทอร์เน็ตและอีเมล

- ห้ามเปิดไฟล์แนบหรือคลิกลิงก์จากอีเมลที่น่าเชื่อถือหรือต้องสงสัยว่าเป็นการหลอกลวง (Phishing)
- ห้ามส่งข้อมูลลับของบริษัทผ่านอีเมลส่วนตัวหรือช่องทางที่ไม่ได้รับอนุญาต
- การเข้าถึงเว็บไซต์ที่มีความเสี่ยงต่อความมั่นคงปลอดภัยจะถูกจำกัดโดยระบบกรองเนื้อหา
- พนักงานต้องเข้ารับการอบรมความตระหนักรู้ด้านความมั่นคงปลอดภัยไซเบอร์อย่างน้อยปีละ 1 ครั้ง

12. การทำงานจากระยะไกลและการเชื่อมต่อ VPN

การเข้าถึงระบบภายในของบริษัทจากภายนอกต้องผ่านช่องทางเครือข่ายส่วนตัวเสมือน (VPN) ที่ได้รับอนุมัติเท่านั้น พร้อมยืนยันตัวตนแบบหลายปัจจัยทุกครั้ง และห้ามใช้เครือข่าย Wi-Fi สาธารณะที่ไม่มีการเข้ารหัสในการเข้าถึงข้อมูลลับของบริษัท

13. การตอบสนองต่อเหตุการณ์ด้านความมั่นคงปลอดภัย

บริษัทกำหนดระดับความรุนแรงของเหตุการณ์และระยะเวลาตอบสนอง ดังนี้:

ระดับความรุนแรง	ตัวอย่างเหตุการณ์	ระยะเวลาตอบสนอง
วิกฤต (Critical)	ข้อมูลลูกค้ารั่วไหล ระบบหลักถูกโจมตีด้วย Ransomware	ภายใน 1 ชั่วโมง
สูง (High)	พบการเข้าถึงระบบโดยไม่ได้รับอนุญาต	ภายใน 4 ชั่วโมง
ปานกลาง (Medium)	พบมัลแวร์บนเครื่องคอมพิวเตอร์รายบุคคล	ภายใน 1 วันทำการ
ต่ำ (Low)	อีเมลหลอกลวงที่ไม่ก่อให้เกิดความเสียหาย	ภายใน 3 วันทำการ

พนักงานทุกคนมีหน้าที่รายงานเหตุการณ์ที่พบหรือสงสัยว่าเป็นเหตุด้านความมั่นคงปลอดภัยต่อฝ่ายเทคโนโลยีสารสนเทศทันที ผ่านช่องทาง it-security@example-business.co.th หรือสายด่วน 02-000-0000 ต่อ 911

14. การตรวจสอบและการปฏิบัติตามนโยบาย

ฝ่ายเทคโนโลยีสารสนเทศจะดำเนินการตรวจสอบการปฏิบัติตามนโยบายเป็นระยะ

รวมถึงการสุ่มตรวจสอบบันทึกการใช้งานระบบ (Log) และอาจจ้างผู้เชี่ยวชาญภายนอกดำเนินการทดสอบเจาะระบบ (Penetration Testing) อย่างน้อยปีละ 1 ครั้ง

15. บทลงโทษกรณีฝ่าฝืนนโยบาย

การฝ่าฝืนนโยบายฉบับนี้ถือเป็นความผิดทางวินัยตามระเบียบข้อบังคับการทำงานของบริษัท

โดยจะพิจารณาโทษตามความร้ายแรงของการกระทำ

ตั้งแต่การตักเตือนจนถึงการเลิกจ้าง

และหากเป็นกรณีที่เข้าข่ายความผิดตามกฎหมาย บริษัทจะดำเนินคดีตามกฎหมายต่อไป

16. การทบทวนนโยบาย

นโยบายฉบับนี้จะได้รับการทบทวนอย่างน้อยปีละ 1 ครั้งโดยฝ่ายเทคโนโลยีสารสนเทศ หรือเมื่อมีการเปลี่ยนแปลงเทคโนโลยี ภัยคุกคาม หรือข้อกำหนดทางกฎหมายที่เกี่ยวข้องอย่างมีนัยสำคัญ

เอกสารนี้เป็นข้อมูลจำลอง (Mock Document) จัดทำขึ้นเพื่อวัตถุประสงค์ในการฝึกอบรมและทดสอบระบบเท่านั้น มิใช่เป็นนโยบายที่มีผลบังคับใช้จริง